

Northstar Payments API — Contract Specification (RFC 2119)

Authority for the REDLINE lane. Every normative line below uses RFC 2119 keyword (**MUST**, **MUST NOT**, **SHALL**, **SHALL NOT**, **REQUIRED**, **FORBIDDEN**, **SHOULD**, **MAY**). The REDLINE lane extracts these into clause-wall entries (W1–W8) and then writes tests that assert the *document*, never the source.

Version: 1.0 | Status: PROPOSED | Owning team: Payments Core

Scope

This specification governs the behavior of the **Northstar Payments** HTTP API and its internal async pipeline. Clause IDs (W1–W8) are the stable identifiers used across the clause wall, REDLINE test suite, and trust-gap evidence.

W1 — Payment intent idempotency (**REQUIRED**)

1. `POST /v1/payment_intents` **MUST** accept an **Idempotency-Key** request header.
2. If the same **Idempotency-Key** is submitted more than once, the API **MUST NOT** create a second payment intent; it **MUST** return the *original* intent resource with the same idempotency key.
3. A new intent **MUST** be created only when the idempotency key has not been seen before for that merchant.
4. Idempotency lookup **MUST** be atomic under concurrent duplicate requests, so that two racing requests with the same key still yield one intent.

W2 — Webhook signature verification (**REQUIRED**)

1. Every inbound Stripe webhook **MUST** be verified against the **Stripe-Signature** header (HMAC-SHA256, timestamp tolerance) before any business logic runs.
2. A payload whose signature does not verify **MUST** be rejected with HTTP 400 and **MUST NOT** trigger any payment side effect.
3. Missing or malformed signature headers **MUST** be treated as verification failure, not silently ignored.

W3 — Refund cap (**REQUIRED**)

1. A refund **MUST NOT** exceed the total captured amount of the original payment.

2. Cumulative refunds against one payment **MUST NOT** exceed the captured amount; each refund **MUST** be checked against the running refunded total.
3. A refund attempt that would exceed the cap **MUST** be rejected and **MUST NOT** create a negative or over-refunded balance.

W4 — Ledger available-vs-pending (REQUIRED)

1. GET /v1/ledger/balances **MUST** report two distinct figures: **available** (spendable) and **pending** (held).
2. Authorization-hold funds **MUST** be reported under **pending** and **MUST NOT** be included in **available**.
3. **available** **MUST** equal settled credits minus settled debits minus pending holds; funds under **pending** **MUST NOT** be spendable.

W5 — Token type interchange (REQUIRED)

1. The implementation **MUST** distinguish JSON Web Token (JWT) access tokens from raw API keys at validation time.
2. A JWT presented to an API-key endpoint, and an API key presented to a JWT-protected endpoint, **MUST** both be rejected.
3. Validation **MUST NOT** fall back to treating either token kind as the other.

W6 — Retry & circuit-breaker discipline (SHALL)

1. Outbound calls receiving a 429 or a 5xx status **SHALL** retry with **exponential backoff plus jitter**.
2. The shared circuit breaker **SHALL NOT** trip on the first transient error; it **SHALL** require the configured consecutive-failure threshold per the runbook before opening.
3. Once open, the breaker **SHALL** serve the runbook fail-fast behavior and **SHALL NOT** be half-open earlier than the runbook's settle window.

W7 — Monetary precision in integer cents (REQUIRED)

1. All currency arithmetic **MUST** be performed in **integer cents**; floats **MUST NOT** be used to represent or compute monetary values.
2. Any conversion that would coerce a cents value to a float for arithmetic **MUST NOT** be performed.
3. Decimal-string inputs (e.g. "12.34") **MUST** be parsed to integer cents exactly (round-half-even) and stored as integers.

W8 — Async worker resilience / no null-deref outage (REQUIRED)

1. The async billing processor **MUST** nil-guard the Stripe customer record before dereference.
 2. A missing/unparseable record **MUST** be isolated to that one item; it **MUST NOT** crash or 500 the whole worker / webhook batch.
 3. A per-item failure **MUST** be recorded and the remaining items in the batch **MUST** still process.
-

Conformance

- A clause is **satisfied** only when a test derived solely from this document's clause text passes against the implementation.
- Clause-wall entries reference these exact IDs; no entry may drift from the MUST/SHALL level stated above.